

ISO 27001:2022 Documentation Checklist

The documents ISO 27001 requires, what auditors expect to see, and what is worth adding. 60 items in four tiers, each mapped to its clause or Annex A control.

[ISO 27001:2022](#) · [Amd 1:2024](#) · [ISO 27002:2022](#) · [ISMS](#) · [POPIA](#)

Work top down and do not skip tier 1. Tier 1 is required by clauses 4 to 10 for every ISMS. Tier 2 is required when your Statement of Applicability includes the related Annex A control. Tier 3 is not mandated, but auditors expect the evidence. Tier 4 builds maturity once the basics are solid. Format is your choice: a record in a system counts as much as a Word file. Clause and control text is paraphrased, so check exact wording against your licensed copy of ISO/IEC 27001:2022 and ISO/IEC 27002:2022. This checklist is guidance, not certification advice.

A Tier 1 · Must have: context, leadership and planning

- ☐ ISMS scope (4.3): boundaries and applicability, including interfaces and dependencies with other organisations.
- ☐ Information security policy (5.2): approved by top management, communicated internally and available to interested parties as appropriate.
- ☐ Risk assessment process (6.1.2): risk acceptance criteria and a method that gives consistent, valid and comparable results.
- ☐ Risk treatment process (6.1.3): how you select treatment options and determine the controls you need.
- ☐ Statement of Applicability (6.1.3 d): all 93 Annex A controls, included or excluded, why, and whether implemented.
- ☐ Risk treatment plan (6.1.3 e, f): actions, owners and timelines. Risk owners approve it and accept residual risk.
- ☐ Information security objectives (6.2): measurable where practicable, with what, who, when, resources and how results are evaluated.

B**Tier 1 · Must have: support, operation, evaluation and improvement**

- ☐ Evidence of competence (7.2 d): training, qualifications or experience for people whose work affects the ISMS.
- ☐ Documented information you deem necessary (7.5.1 b): whatever your ISMS needs to be effective. You decide the extent, so decide deliberately.
- ☐ Operational planning and control (8.1): enough evidence to show processes ran as planned, including externally provided ones.
- ☐ Risk assessment results (8.2): assessments at planned intervals and when significant changes occur.
- ☐ Risk treatment results (8.3): proof the treatment plan is actually being implemented.
- ☐ Monitoring and measurement results (9.1): what you measured, how, when, and what the results show.
- ☐ Internal audit programme and results (9.2.2): frequency, methods, responsibilities and criteria, plus the audit reports.
- ☐ Management review results (9.3.3): decisions on improvement opportunities and any changes needed to the ISMS.
- ☐ Nonconformities and corrective actions (10.2): what went wrong, what you did about it, and whether it worked.

C**Tier 2 · If applicable: policies, assets and access**

- ☐ Topic-specific policies (A.5.1): for example access control, cryptography, backup and supplier security. Approved and reviewed.
- ☐ Roles and responsibilities (A.5.2): information security roles defined and allocated to suit the organisation.
- ☐ Inventory of information and assets (A.5.9): information and associated assets, each with an owner. Kept current.
- ☐ Acceptable use rules (A.5.10): rules and handling procedures for information and assets, documented and implemented.
- ☐ Classification scheme (A.5.12): levels based on confidentiality, integrity, availability and interested party requirements.
- ☐ Access control rules (A.5.15): physical and logical access rules based on business and security requirements.

D Tier 2 · If applicable: suppliers, incidents, continuity and operations

- ☐ Supplier security requirements (A.5.19, A.5.20): processes to manage supplier risk, and agreed requirements in each relevant contract.
- ☐ Incident management process (A.5.24): processes, roles and responsibilities defined, established and communicated.
- ☐ ICT readiness for business continuity (A.5.30): planned, implemented, maintained and tested against continuity objectives.
- ☐ Legal, regulatory and contractual requirements (A.5.31): identified, documented and kept up to date. In South Africa, include POPIA.
- ☐ Documented operating procedures (A.5.37): for information processing facilities, available to the people who need them.
- ☐ Confidentiality agreements (A.6.6): NDAs that reflect your needs, identified, documented, reviewed and signed.
- ☐ Configuration management (A.8.9): security configurations established, documented, monitored and reviewed.
- ☐ Secure development rules (A.8.25): rules for secure development of software and systems, if you build or change them.
- ☐ Change management procedures (A.8.32): changes to systems and processing facilities follow defined procedures.

E Tier 3 · Best practice: context, risk and people

- ☐ Internal and external issues (4.1): context analysis, including whether climate change is relevant (Amendment 1:2024).
- ☐ Interested parties register (4.2): who they are, their requirements, and which ones the ISMS addresses.
- ☐ Roles matrix, RACI (5.3): shows who is accountable for ISMS conformity and for reporting performance.
- ☐ Risk register (6.1.2, 8.2): a living record of risks, owners, ratings and treatment status.
- ☐ Risk acceptance and exceptions register (6.1.3 f): approved deviations with owner, expiry date and compensating controls.
- ☐ Communication plan (7.4): what, when, with whom and how. The standard requires you to decide, not to document.
- ☐ Awareness programme and attendance (7.3): proves people know the policy, their contribution and the cost of nonconformity.
- ☐ Competence matrix (7.2): required skills against actual, with gaps and plans to close them.

F Tier 3 · Best practice: control, evaluation and operating evidence

- ☐ Document control procedure (7.5): versioning, approval, review cycle, access and retention in one place.
- ☐ Measurement plan (9.1): each metric with owner, frequency, target and data source.
- ☐ Internal audit plan and checklists (9.2): shows every clause and included control is covered over the audit cycle.
- ☐ Management review pack and minutes (9.3.2): inputs, attendance, discussion and decisions, ready to show.
- ☐ Incident register and reviews (A.5.24 to A.5.27): evidence of detection, response and lessons learned.
- ☐ Supplier register with risk ratings (A.5.19 to A.5.22): supports monitoring and review of supplier services.
- ☐ Business impact analysis (A.5.30): sets the recovery time and recovery point objectives that continuity plans must meet.
- ☐ Vulnerability scans and penetration tests (A.8.8): evidence of technical vulnerability management and remediation.
- ☐ Access review records (A.5.18): periodic review of access rights, with removals actioned.
- ☐ Backup restore test records (A.8.13): proof that backups restore, not just that they run.

G Tier 4 · Nice to have: governance and reporting

- ☐ ISMS handbook (overview): a short guide to how your ISMS fits together, for staff and auditors.
- ☐ Gap assessment (baseline): a starting point before certification, transition or a major change.
- ☐ ISMS annual calendar (planning): reviews, audits, tests and training in one view.
- ☐ Board reporting pack (governance): translates ISMS performance into business risk for directors.
- ☐ Security metrics dashboard (performance): trends over time, not just point-in-time audit evidence.
- ☐ Policy attestation records (assurance): staff confirm they have read and accepted key policies.

H Tier 4 · Nice to have: resilience and assurance

- ☐ Tabletop and continuity exercises (resilience): tests decisions and communication, not only technology.
- ☐ Threat intelligence summaries (A.5.7): regular, relevant threat insight that feeds risk assessment.
- ☐ Supplier assurance pack (assurance): key suppliers' certificates or independent assurance reports on file.
- ☐ Lessons-learned log (improvement): one place for insight from incidents, audits and exercises.
- ☐ Certification history (records): past certificates and certification body reports, for trends and continuity.